Saudi GRC Platform

Workbook Spec

Source: `workbook-spec.md`

18 — Excel Workbook Structure

Companion to the deliverable package: a single `.xlsx` workbook with 23 named sheets, each defining one table the implementation team can hand to BAs / config consultants / customer DBAs. The file lives at `./tss-grc-implementation-package.xlsx` in this folder.

Workbook conventions:

- Sheet name = concise English (≤ 31 chars per Excel limit).
- Row 1 = column headers (bold).
- Row 2 = the example row (italic, light-grey fill).
- Row 3 onwards = the seeded reference data.
- Data validation: dropdowns for enum columns; date format `YYYY-MM-DD`; numeric columns formatted with thousand separators.
- Mandatory columns marked with a `*` in the header.

Sheet 1 — Module Catalogue

Column	Type	Mand.	Dropdown / Validation	Example
Module Code	text	✓	—	RISK
Module Name EN	text	✓	—	Enterprise Risk Management
Module Name AR	text	—	—	■■■■■ ■■■■■■■■ ■■■■■■■■
Backend Package	text	✓	starts with module.	module.risk
Frontend Route Root	text	✓	—	/risk
Primary Persona	dropdown	✓	Risk Mgr / BCM Mgr / DPO / CISO / Compliance Officer / Supplier Mgr / Auditor	Risk Manager
Status	dropdown	✓	DONE / IN_PROGRESS / PLANNED	DONE
Sprint Origin	text	—	sprint-N	sprint-1
Key Frameworks	text	—	comma-separated	NCA ECC, SAMA, ISO 31000

Sheet 2 — Workflow Catalogue

Column	Type	Mand.	Validation	Example
Workflow Code	text	✓	unique	RISK_ACCEPTANCE
Workflow Name EN	text	✓	—	Risk acceptance above appetite

Column	Type	Mand.	Validation	Example
Workflow Name AR	text	✓	—	■■■■ ■■■■■■■ ■■■ ■■■■
Module Code	dropdown	✓	from Sheet 1	RISK
Trigger	text	✓	—	Residual > appetite ceiling
SLA (days)	number	—	≥ 0	14
Signature Required	dropdown	✓	YES / NO	YES
Status Lifecycle	text	✓	arrow-chained	REQUESTED → APPROVED → ACTIVE → EXPIRED
Primary Actor	text	✓	—	Risk Owner
Approver	text	✓	—	CRO
Evidence Required	text	—	comma-separated	Risk acceptance memo

Sheet 3 — Workflow Steps

Column	Type	Mand.	Validation	Example
Workflow Code	dropdown	✓	from Sheet 2	RISK_ACCEPTANCE
Step Order	number	✓	≥ 1	1
Step Name EN	text	✓	—	Submit acceptance request
Step Name AR	text	—	—	■■■■■ ■■■ ■■■■■■
Actor Role	text	✓	—	Risk Owner
Input	text	—	—	Justification + residual score
Output	text	—	—	REQUESTED status
Decision Point	dropdown	—	YES / NO	NO
SLA Hours	number	—	≥ 0	24

Sheet 4 — Role Matrix

Column	Type	Mand.	Validation	Example
Role Code	text	✓	unique	RISK_MGR
Role Name EN	text	✓	—	Risk Manager
Role Name AR	text	—	—	■■■■ ■■■■■■■
Module Code	dropdown	✓	from Sheet 1	RISK
View	dropdown	✓	ALL / OWN / NONE	ALL
Create	dropdown	✓	ALL / OWN / NONE	ALL
Edit	dropdown	✓	ALL / OWN / NONE	ALL

Column	Type	Mand.	Validation	Example
Approve	dropdown	✓	YES / NO	YES
Delete	dropdown	✓	ALL / OWN / NONE	OWN
Export	dropdown	✓	YES / NO	YES
Sign	dropdown	✓	YES / NO	YES
Report	dropdown	✓	YES / NO	YES

Sheet 5 — Approval Matrix

Column	Type	Mand.	Validation	Example
Workflow Code	dropdown	✓	from Sheet 2	RISK_ACCEPTANCE
Approval Level	number	✓	1..5	1
Approver Role	text	✓	—	CRO
Threshold Condition	text	—	—	Residual > appetite
Mandatory	dropdown	✓	YES / NO	YES
Signature Required	dropdown	✓	YES / NO	YES
SLA Hours	number	—	≥ 0	48

Sheet 6 — Data Objects

Column	Type	Mand.	Validation	Example
Object Code	text	✓	unique	Risk
Schema	text	✓	—	risk
Table Name	text	✓	—	risks
Module	dropdown	✓	from Sheet 1	RISK
Lifecycle	text	—	—	DRAFT → ASSESSED → APPROVED
Owner Field	text	—	—	risk_owner_user_id
Bilingual	dropdown	✓	YES / NO	YES
Description EN	text	✓	—	Enterprise-level risk record
Description AR	text	—	—	■■■ ■■■■■■■ ■■■ ■■■■■ ■■■■■■■

Sheet 7 — Entity Relationships

Column	Type	Mand.	Validation	Example
Parent Object	dropdown	✓	from Sheet 6	Risk
Child Object	dropdown	✓	from Sheet 6	RiskAssessment

Column	Type	Mand.	Validation	Example
Relationship Type	dropdown	✓	1:1 / 1:N / M:N	1:N
FK Column	text	✓	—	risk_id
Cascade Behaviour	dropdown	✓	CASCADE / SET_NULL / RESTRICT	RESTRICT
Bidirectional	dropdown	✓	YES / NO	YES

Sheet 8 — UI Screens

Column	Type	Mand.	Validation	Example
Screen Code	text	✓	unique	RISK_REGISTER
Page Path	text	✓	starts with /	/risk
Title EN	text	✓	—	Risk Register
Title AR	text	✓	—	■■■ ■■■■■■■
Layout	dropdown	✓	LIST / DETAIL / DASHBOARD / FORM / WIZARD / PORTAL	LIST
Module	dropdown	✓	from Sheet 1	RISK
Primary Persona	text	✓	—	Risk Manager
RTL Behaviour	text	—	—	Logical CSS; header right-align
Required Role	text	—	—	RISK_READ

Sheet 9 — UI Fields

Column	Type	Mand.	Validation	Example
Screen Code	dropdown	✓	from Sheet 8	RISK_REGISTER
Field Code	text	✓	—	riskCode
Field Type	dropdown	✓	text / textarea / number / date / select / multiselect / file / signature	text
Label EN	text	✓	—	Code
Label AR	text	✓	—	■■■■■
Required	dropdown	✓	YES / NO	YES
Validation	text	—	—	regex / min / max
Default Value	text	—	—	—
Help Text EN	text	—	—	Unique identifier

Sheet 10 — Evidence Library

Column	Type	Mand.	Validation	Example
Evidence Code	text	✓	unique	EV_BIA_REPORT
Name EN	text	✓	—	BIA Report
Name AR	text	—	—	■■■■■ ■■■■■ ■■■ ■■■■■■■
Owner Role	text	✓	—	BIA Owner
Frequency	dropdown	✓	DAILY / WEEKLY / MONTHLY / QUARTERLY / ANNUAL / PER_EVENT / ON_DEMAND	ANNUAL
File Types	text	✓	comma-separated	pdf, xlsx
Expiry Rule	text	✓	—	12 months
Approval Role	text	✓	—	BCM Manager
Module	dropdown	✓	from Sheet 1	BCM
Regulatory Source	text	✓	—	ISO 22301 §8.2.2
Signature Required	dropdown	✓	YES / NO	YES

Sheet 11 — Regulatory Mapping

Column	Type	Mand.	Validation	Example
Source	dropdown	✓	NCA / SAMA / SDAIA / DGA / NRC / ISO 22301 / ISO 27001 / ISO 31000 / ISO 27701 / PCI DSS	NCA
Domain	text	✓	—	ECC Governance
Control / Requirement ID	text	✓	unique within Source	ECC-1-1
Title EN	text	✓	—	Cybersecurity strategy
Title AR	text	—	—	■■■■■■■■■■ ■■■■■ ■■■■■■■■■■
Module	dropdown	✓	from Sheet 1	CYBER
Workflow Code	dropdown	—	from Sheet 2	NCA_SELF_ASSESSMENT
Evidence Code	dropdown	—	from Sheet 10	EV_STRATEGY_DOC
Responsible Role	text	✓	—	CISO
Status	dropdown	✓	NOT_APPLICABLE / NOT_IMPLEMENTED / PLANNED / PARTIAL / IMPLEMENTED / VERIFIED	IMPLEMENTED

Column	Type	Mand.	Validation	Example
Placeholder	dropdown	✓	YES / NO	NO

Sheet 12 — Controls Library

Column	Type	Mand.	Validation	Example
Control Code	text	✓	unique	ECC-1-1
Framework	dropdown	✓	NCA ECC / NCA CSCC / NCA CCC / NCA OTCC / SAMA / ISO 27001 / ISO 22301 / PCI DSS	NCA ECC
Domain	text	✓	—	Governance
Title EN	text	✓	—	Cybersecurity strategy
Title AR	text	—	—	■■■■■■■■■■ ■■■■■ ■■■■■■■■■
Type	dropdown	✓	PREVENTIVE / DETECTIVE / CORRECTIVE	PREVENTIVE
Review Frequency	dropdown	✓	ANNUAL / QUARTERLY / MONTHLY / CONTINUOUS / SEMI_ANNUAL	ANNUAL
Maturity Level	dropdown	✓	L1 / L2 / L3 / L4 / L5	L4
Implementation Status	dropdown	✓	IMPLEMENTED / PARTIAL / PLANNED / NOT_APPLICABLE / NOT_IMPLEMENTED	IMPLEMENTED
Owner	text	—	—	CISO Office

Sheet 13 — Risk Register

Column	Type	Mand.	Validation	Example
Risk Code	text	✓	unique	RSK-2026-001
Title EN	text	✓	—	Aramco contract migration delay
Title AR	text	—	—	■■■■■ ■■■■■ ■■■ ■■■■■■
Category	dropdown	✓	Strategic / Operational / Financial / Cyber / Regulatory / Reputational	Operational
Inherent Likelihood	number	✓	1..5	4
Inherent Impact	number	✓	1..5	4

Column	Type	Mand.	Validation	Example
Residual Likelihood	number	✓	1..5	3
Residual Impact	number	✓	1..5	3
Treatment	dropdown	✓	AVOID / MITIGATE / TRANSFER / ACCEPT	ACCEPT
Owner	text	✓	—	COO
Appetite Band	dropdown	✓	GREEN / AMBER / RED	AMBER
Status	dropdown	✓	DRAFT / ASSESSED / APPROVED / ACCEPTED / MITIGATED / CLOSED	ACCEPTED
Acceptance Expiry	date	—	YYYY-MM-DD	2027-05-11

Sheet 14 — BIA Register

Column	Type	Mand.	Validation	Example
BIA Code	text	✓	unique	BIA-001
Service Name EN	text	✓	—	Customer onboarding & KYC
Service Name AR	text	—	—	■■■■■ ■■■■■■■ ■■■■■■■■■ (KYC)
MTPD (h)	number	✓	≥ 1	24
RTO (h)	number	✓	≤ MTPD	4
RPO (h)	number	✓	≤ MTPD	1
MBCO (%)	number	—	0..100	50
Financial Impact (SAR)	number	—	≥ 0	250000
Regulatory Impact	dropdown	—	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Reputational Impact	dropdown	—	LOW / MEDIUM / HIGH / CRITICAL	MEDIUM
Operational Impact	dropdown	—	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Owner	text	✓	—	Head of Retail
Last Reviewed	date	✓	YYYY-MM-DD	2026-03-15
Status	dropdown	✓	DRAFT / SCORING / IN_REVIEW / APPROVED / SUPERSEDED	APPROVED

Sheet 15 — Supplier Register

Column	Type	Mand.	Validation	Example
Vendor Code	text	✓	unique	VND-0042
Vendor Name EN	text	✓	—	Solutions by STC
Vendor Name AR	text	—	—	■■■■■■ ■■ STC
Country	text	—	ISO-3	SAU
Sector	text	—	—	Telecom
Criticality	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	CRITICAL
Contract Start	date	—	YYYY-MM-DD	2024-01-01
Contract End	date	—	YYYY-MM-DD	2027-01-01
Risk Rating	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Status	dropdown	✓	DRAFT / KYC_PENDING / ACTIVE / SUSPENDED / CLOSED	ACTIVE
Last Assessment Date	date	—	YYYY-MM-DD	2026-03-15

Sheet 16 — PDPL Processing Register (ROPA)

Column	Type	Mand.	Validation	Example
ROPA Code	text	✓	unique	ROPA-001
Activity Name EN	text	✓	—	Customer onboarding & KYC
Activity Name AR	text	—	—	■■■■■ ■■■■■■■
Purpose	text	✓	—	KYC + AML compliance
Lawful Basis	dropdown	✓	CONSENT / LEGAL_OBLIGATION / CONTRACT / VITAL_INTEREST / PUBLIC_INTEREST / LEGITIMATE_INTEREST	LEGAL_OBLIGATION
Data Categories	text	✓	comma-separated	IDENTITY, CONTACT, FINANCIAL
Data Subjects	text	✓	—	CUSTOMER
Source Asset	text	—	—	SQL Server primary (DB-PRIMARY)
Residency	text	—	ISO-3	SAU
Cross-Border	dropdown	✓	YES / NO	NO
Retention (days)	number	—	≥ 0	3650
Owner	text	✓	—	DPO

Column	Type	Mand.	Validation	Example
Last Reviewed	date	✓	YYYY-MM-DD	2026-03-27
Status	dropdown	✓	DRAFT / ACTIVE / ARCHIVED	ACTIVE

Sheet 17 — NCA Assessment Register

Column	Type	Mand.	Validation	Example
Assessment Code	text	✓	unique	NCA-ECC-2026-Q1
Framework	dropdown	✓	NCA ECC / NCA CSCC / NCA CCC / NCA OTCC	NCA ECC
Control Code	dropdown	✓	from Sheet 12	ECC-1-1
Assessment Type	dropdown	✓	SELF / EXTERNAL / REGULATOR	SELF
Maturity Level	dropdown	✓	L1..L5	L4
Implementation Status	dropdown	✓	IMPLEMENTED / PARTIAL / PLANNED / NOT_APPLICABLE / NOT_IMPLEMENTED	IMPLEMENTED
Evidence Refs	text	—	comma-separated	EV-2026-CISO-STRAT
Assessor	text	✓	—	CISO Office
Assessed At	date	✓	YYYY-MM-DD	2026-04-01
Approver	text	—	—	CISO
Approved At	date	—	YYYY-MM-DD	2026-04-10
Status	dropdown	✓	DRAFT / IN_REVIEW / APPROVED / FILED	APPROVED

Sheet 18 — Incident Register

Column	Type	Mand.	Validation	Example
Incident Code	text	✓	unique	INC-2026-001
Title EN	text	✓	—	Phishing campaign affecting finance team
Title AR	text	—	—	■■■■ ■■■■ ■■■■ ■■■■ ■■■■■■■
Severity	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	HIGH
Classification	dropdown	✓	CYBER / PHYSICAL / OPERATIONAL / VENDOR / PRIVACY	CYBER
Detected At	date	✓	YYYY-MM-DD	2026-04-19

Column	Type	Mand.	Validation	Example
Phase	dropdown	✓	DETECTION / ANALYSIS / CONTAINMENT / ERADICATION / RECOVERY / POST_INCIDENT / LESSONS_LEARNED / CLOSED	LESSONS_LEARNED
Impacted Assets	text	—	comma-separated	DB-PRIMARY, MAIL-GW
Regulator Notified	dropdown	✓	YES / NO	YES
Notification Reference	text	—	—	NCA-2026-1023
Assignee	text	✓	—	SOC Lead
Linked Breach	text	—	—	BR-2026-005

Sheet 19 — Corrective Action Register

Column	Type	Mand.	Validation	Example
CAPA Code	text	✓	unique	CAPA-202604-0011
Origin Type	dropdown	✓	rca / processor_assessment / supplier_resilience_test / fourth_party_exposure / audit_finding / bia_gap / kri_breach / compliance_gap	processor_assessment
Origin ID	text	✓	—	PROC-2026-008
Title EN	text	✓	—	PDPL Art. 28 FAIL — Sentry IO
Title AR	text	—	—	■■■■■ ■■■■■■ 28 — Sentry IO
Type	dropdown	✓	CORRECTIVE / PREVENTIVE	CORRECTIVE
Severity	dropdown	✓	LOW / MEDIUM / HIGH / CRITICAL	CRITICAL
Owner Role	text	✓	—	DPO
Target Date	date	✓	YYYY-MM-DD	2026-06-25
Status	dropdown	✓	OPEN / IN_PROGRESS / AWAITING_VERIFICATION / CLOSED / CANCELLED	OPEN

Sheet 20 — Reports Catalogue

Column	Type	Mand.	Validation	Example
Report Code	text	✓	unique	RPT_BOARD_RISK

Column	Type	Mand.	Validation	Example
Title EN	text	✓	—	Board Risk Report
Title AR	text	✓	—	■■■■■ ■■■■■■■ ■■■■■ ■■■■■■■
Audience	text	✓	—	Board, CRO, Audit Committee
Cadence	dropdown	✓	QUARTERLY / MONTHLY / ANNUAL / ON_DEMAND	QUARTERLY
Formats	text	✓	comma-separated	PDF, PPTX, XLSX
Signature Required	dropdown	✓	YES / NO	YES
Approver	text	✓	—	Chairman

Sheet 21 — Automation Rules

Column	Type	Mand.	Validation	Example
Rule Code	text	✓	unique	RULE_PROC_FAIL_CAPA
Trigger	text	✓	—	ProcessorAssessment.scoreAndComplete
Condition	text	✓	—	overallOutcome = FAIL
Action	text	✓	—	Create CAPA with originType=processor_assessment
Notify	text	—	—	DPO, CISO
Escalation	text	—	—	day-45 if not started
Suppressable	dropdown	✓	YES / NO	YES
Module	dropdown	✓	from Sheet 1	PRIVACY

Sheet 22 — Test Cases

Column	Type	Mand.	Validation	Example
Test Case ID	text	✓	unique	TC-PROC-FAIL-001
Workflow Code	dropdown	✓	from Sheet 2	PROCESSOR_ASSESSMENT
Scenario	text	✓	—	Score processor with c4 FAIL
Preconditions	text	✓	—	IN_PROGRESS assessment exists
Steps	text	✓	numbered	1. Open assessment. 2. Submit c4=FAIL. 3. Confirm.
Expected Result	text	✓	—	overallOutcome FAIL; CAPA opened

Column	Type	Mand.	Validation	Example
User Role	text	✓	—	DPO
Pass/Fail Criteria	text	✓	—	New row in capa.tasks

Sheet 23 — Sample Data

Column	Type	Mand.	Validation	Example
Entity	dropdown	✓	Organisation / User / Service / Asset / Vendor / Risk / Processing Activity / Incident / Breach / CAPA / Evidence / Policy / Framework / Control	Risk
Tenant	text	✓	—	tss-bank
Code	text	✓	—	RSK-2026-001
Title EN	text	✓	—	Aramco contract migration delay
Title AR	text	—	—	■■■■■ ■■■■■ ■■■ ■■■■■■
Created At	date	✓	YYYY-MM-DD	2026-01-15
Status	text	✓	—	ACCEPTED
Notes	text	—	—	Linked to acceptance ACC-2026-007

How to consume

- **BA / config consultant:** copy the workbook, fill the rows, send it back to engineering — every column maps to a backend field. The `Validation` column tells you what values are legal.
- **Customer DBA:** the `Schema` + `Table Name` columns in Sheet 6 are the canonical mapping; foreign keys in Sheet 7 give the join paths.
- **QA:** Sheets 22 + 23 are directly importable into a test-management tool.
- **Regulator audit:** Sheets 10 (Evidence), 11 (Regulatory Mapping), 17 (NCA Assessment Register) cover the typical audit-evidence questionnaire.

A working `.xlsx` is committed alongside this file at `./tss-grc-implementation-package.xlsx`. Open in any spreadsheet client; no macros, no external links.